



Upload Shell



Bối cảnh (Context)

Diễn đàn chia sẻ ảnh "ImgShare" đang mở sự kiện thi ảnh đẹp. Người dùng có thể đăng ký tài khoản và tải lên các bức ảnh với định dạng .png hoặc .jpg. Đội ngũ quản trị tự tin rằng họ đã kiểm tra kỹ đuôi file tải lên trên Frontend bằng JavaScript để ngăn chặn mã độc.

Nhưng có vẻ họ quên rằng hacker không dùng trình duyệt thông thường để gửi yêu cầu, và backend server cũng chỉ kiểm tra file một cách hời hợt.



Mục tiêu (Objective)

- **Nhiệm vụ:** Tải lên một mã độc (Web Shell) để chiếm quyền điều khiển máy chủ và tìm đọc file chứa Flag nằm trên hệ thống.
- **Vấn đề / Lỗ hổng: Unrestricted File Upload.** Cơ chế kiểm duyệt file tải lên chỉ kiểm tra ở Frontend (dễ dàng bypass bằng Proxy) hoặc chỉ kiểm tra đuôi file / Content-Type yếu ớt ở Backend. Khi đưa được Web Shell (ví dụ `.php`) lên máy chủ, ứng dụng có thể thực thi nó thay vì coi nó là file ảnh.
- **Flag:** Đọc được cấu hình hoặc file `/flag.txt` trên máy chủ.



Gợi ý (Hints)

- Dùng Burp Suite bắt request khi upload ảnh, thử đổi tên file từ `image.png` thành `shell.php`.
- Thử đổi đuôi file thành các định dạng ít phổ biến hơn như `.php5`, `.phtml`, hoặc tải lên tên file `.php.jpg` nếu server cấu hình sai.
- Hãy chuẩn bị một payload shell PHP đơn giản như `<?php system($_GET['cmd']); ?>`.